

Análisis de Riesgos de Seguridad de la Información

Proyecto Final — Seguridad de Sistemas Informáticos
Universidad Mariano Gálvez de Guatemala, 2026



Resumen del Proyecto

15 Activos

Tecnológicos y humanos evaluados en 3 ambientes: Producción, Pruebas y Desarrollo

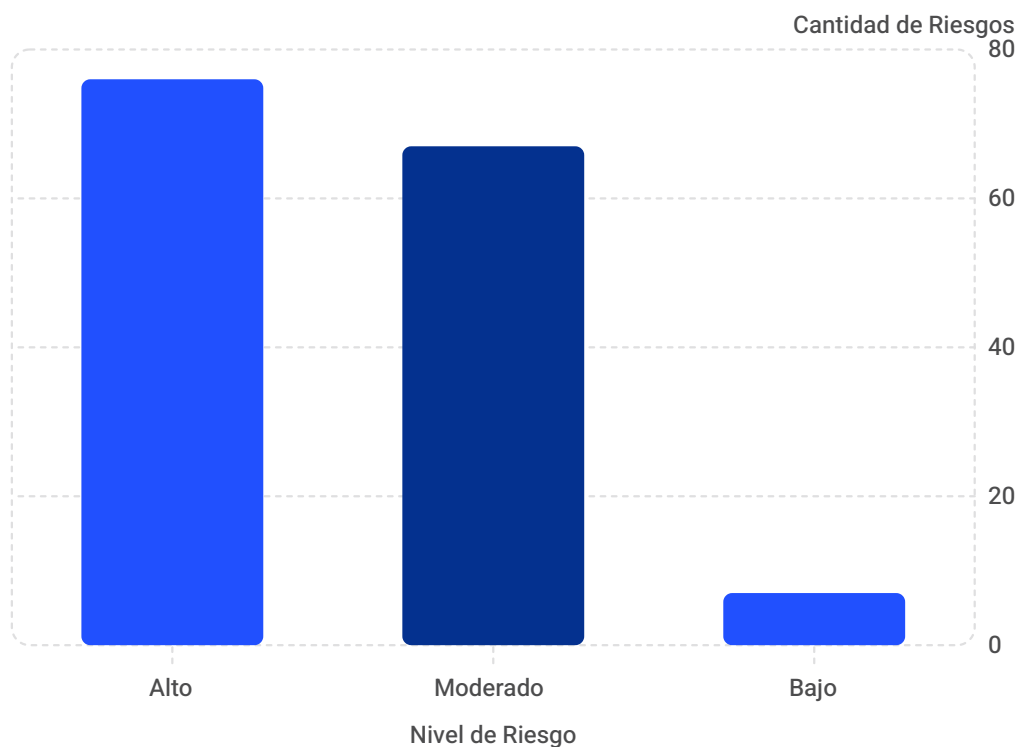
10 Capas

Modelo de defensa en profundidad aplicado de forma uniforme a cada activo

150 Riesgos

Analizados con MAGERIT y OCTAVE Allegro, complementadas con OWASP Top 10

Resultados Globales



Distribución MAGERIT

Sin riesgos críticos registrados. Sin embargo, **76 de los 150 riesgos** (poco más de la mitad) se clasificaron como nivel **Alto**, evidenciando una superficie de exposición considerable que exige un plan de tratamiento priorizado.

Top 10 Riesgos de Mayor Puntaje MAGERIT

Activo – Capa	Amenaza	Puntaje
Código fuente y credenciales – Seguridad de Aplicación	Exposición de credenciales al publicar código	20
Servidor de Base de Datos – Seguridad de Host	Explotación de vulnerabilidades conocidas	16
Código fuente y credenciales – Seguridad de Host	Robo de credenciales en archivos locales	16
Herramienta de automatización – Seguridad de Aplicación	Exposición de credenciales de otros sistemas	16
Servidor de pruebas – Seguridad Perimetral	Ataques de fuerza bruta desde internet	16
Servidor de Base de Datos – Concientización y Procesos	Falta de gestión formal de parches	16
Desarrollador – Seguridad de Aplicación	Introducción de vulnerabilidades en el software	16
Datos de clientes – Seguridad de Red	Intercepción de información personal en tránsito	15
Administrador de sistemas – Seguridad de Aplicación	Uso indebido de accesos privilegiados	15
Sistema ERP/Facturación – Gestión de Identidad y Acceso	Fraude interno o modificación indebida de facturas	15

Plan de Tratamiento por Fases

1

Fase 1 — 0 a 3 meses

15 riesgos de mayor puntaje (15–20).
Acción inmediata sobre activos críticos:
ERP/Facturación, Servidor de Base de
Datos y Código Fuente.

2

Fase 2 — 3 a 6 meses

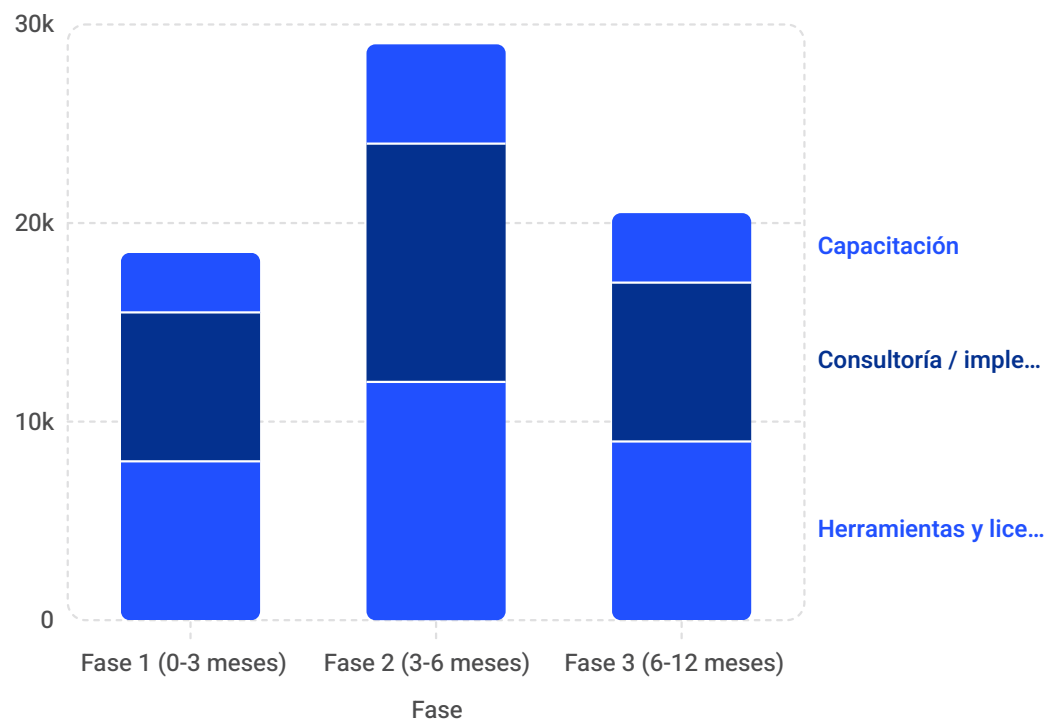
61 riesgos altos restantes (12–15).
Cifrado, MFA, segmentación VLAN y
gestión de accesos privilegiados (PAM).

3

Fase 3 — 6 a 12 meses

67 riesgos moderados y 7 bajos.
Hardening, SIEM centralizado y
capacitación continua del personal.

Inversión Financiera por Fase



Distribución por fase (USD)

La inversión se concentra en la **Fase 2** (USD 29,000), donde se abordan la mayoría de los riesgos altos restantes. La **Fase 1** (USD 18,500) prioriza los 15 riesgos de mayor impacto. La **Fase 3** (USD 20,500) completa el tratamiento con hardening y capacitación continua.

Inversión Total Estimada

\$68,000

Sin contingencia

Inversión base total en herramientas,
consultoría e implementación

\$6,800

Contingencia (10%)

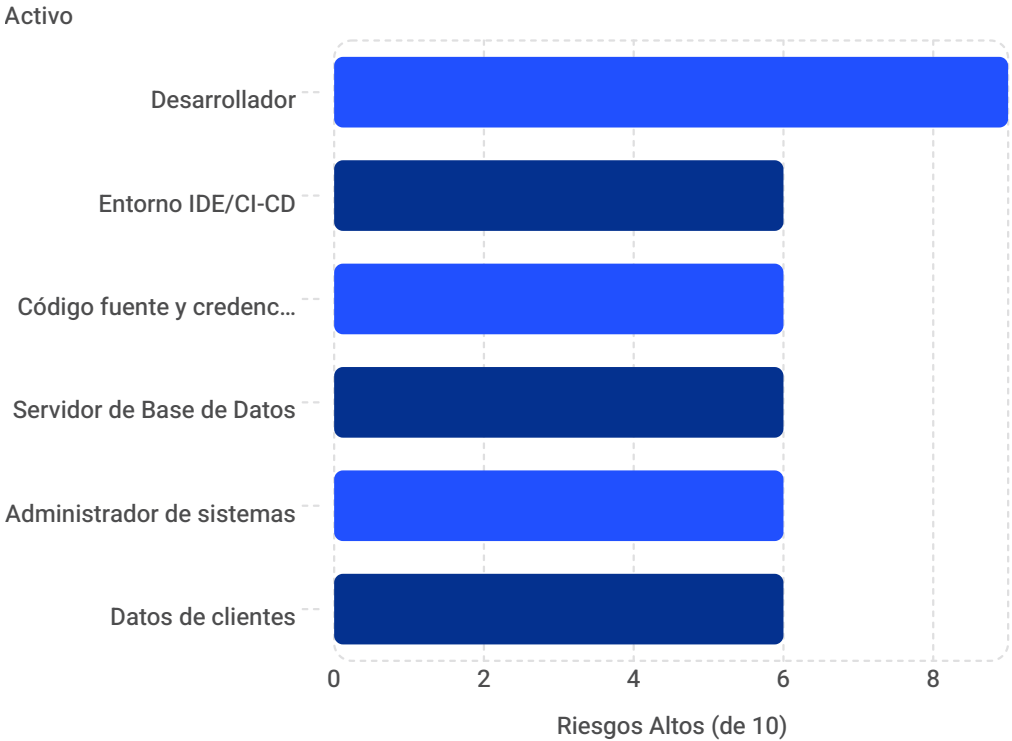
Reserva para imprevistos durante la
implementación del plan

\$74,800

Inversión total estimada

Prioriza primero riesgos con impacto
financiero directo: ERP/Facturación y
Servidor de Base de Datos

Activos con Mayor Concentración de Riesgos Altos



Interpretación

El activo **Desarrollador** lidera con 9 de 10 riesgos en nivel alto, reflejando la exposición del factor humano en el ciclo de desarrollo.

Los activos de datos críticos y el Servidor de Base de Datos concentran **6 de 10** riesgos altos cada uno, confirmando su criticidad operativa y financiera.

Marco Normativo y Continuidad de Negocio

Cumplimiento Normativo

Guatemala: Ley de Acceso a la Información Pública (Decreto 57-2008) y reformas al Código Penal sobre delitos informáticos.

Internacional: MAGERIT, OCTAVE Allegro, ISO/IEC 27005, OWASP Top 10. Se recomienda evaluar aplicabilidad de PCI DSS y RGPD según el tipo de datos procesados.

Objetivos de Recuperación (RTO/RPO)

Activo	RTO	RPO
Sistema ERP/Facturación	4 h	1 h
Servidor de Base de Datos	4 h	1 h
Repositorio Git	8 h	24 h
Estación de desarrollo	24 h	24 h

Conclusiones

Exposición significativa sin riesgos críticos

El análisis no reveló riesgos críticos, pero **76 de 150 riesgos** son de nivel alto, concentrados en aplicación, identidad, red y datos.

Inversión escalonada de ≈USD 74,800

Reduce el impacto financiero de incidentes de alto costo: fraude interno, fuga de datos y explotación de vulnerabilidades conocidas.

La seguridad es un proceso continuo

Revisión periódica de riesgos, actualización de controles y continuidad operativa deben integrarse en un ciclo de mejora permanente.

